2026-05-10 — Gemini ISC2 SSCP Mock Exam (125 Questions + Score)

Performance Summary

Domains: Domain 1, 2 & 3

Metric	Value
Total Questions	125
Correct Answers	114
Incorrect Answers	11
Score	91,2%

Strengths

- Security Frameworks and Principles: You have a solid grasp of the CIA Triad (Confidentiality, Integrity, Availability), the AAA framework, and the STRIDE threat modeling categories. Your understanding of concepts like Non-repudiation and Defense in Depth is excellent.
- Access Control Models: You correctly identified characteristics of Mandatory Access Control (MAC), Role-Based Access Control (RBAC), and Attribute-Based Access Control (ABAC), showing a strong understanding of how different systems manage user permissions.
- Quantitative Risk Analysis: You demonstrated high proficiency in calculating metrics like SLE and ALE, and you understand the relationship between asset value and exposure factors.

Areas to improve

- Logical vs. Administrative Control Categorization: You occasionally confuse technical preventive controls (like password complexity) with detective ones (like antivirus alerts). Reviewing the specific functions of 'Preventive' vs. 'Detective' controls will help sharpen this distinction.
- Business Continuity and Operational States: There was some confusion between 'Fail-safe' (security-focused) and 'Fail-over' (availability-focused). It would be beneficial to review how systems handle failures in high-security environments.

- Roles and Responsibilities: You mixed up the responsibilities of a Data Custodian (technical implementation) with a Data Owner (decision-making). Reviewing the specific duties of data-related roles in an organization is recommended.

Complete Question Set

Question 1

Which principle of the CIA Triad is primarily concerned with ensuring that sensitive information is not disclosed to unauthorized individuals?

- **Correct Answer: Confidentiality**
- Your Answer: Confidentiality

Rationale: Confidentiality is the protection of information from unauthorized access or disclosure.

Question 2

An organization implements a policy where an employee's access rights are automatically revoked when they change roles. This is an example of which security concept?

- **Correct Answer: Least Privilege**
- Your Answer: Separation of Duties

Rationale: Least Privilege ensures users have only the minimum access necessary for their current job. Separation of Duties divides tasks among multiple people.

Question 3

Which access control model is based on user roles and responsibilities within an organization?

- **Correct Answer: RBAC**
- Your Answer: RBAC

Rationale: Role-Based Access Control assigns permissions based on job functions.

Question 4

What is the primary goal of Risk Identification?

- **Correct Answer: To document potential threats and vulnerabilities**
- Your Answer: To document potential threats and vulnerabilities

Rationale: Identification is the first step in creating a risk register or list of potential issues.

Question 5

In Risk Management, what is the term for a weakness in an asset that can be exploited by a threat?

- **Correct Answer: Vulnerability**
- Your Answer: Vulnerability

Rationale: A vulnerability is a flaw or gap in security protection.

Question 6

Which of the following is considered a 'Logical' or 'Technical' access control?

- **Correct Answer: Firewall rules**
- Your Answer: Firewall rules

Rationale: Technical controls use technology like encryption or network hardware.

Question 7

An administrator calculates the Single Loss Expectancy (SLE) to be $2000 and the Annual Rate of Occurrence (ARO) to be 5. What is the Annual Loss Expectancy (ALE)?

- **Correct Answer: $10000**
- Your Answer: $10000

Rationale: ALE is calculated as SLE multiplied by ARO.

Question 8

What is the main difference between 'Risk Transfer' and 'Risk Mitigation'?

- **Correct Answer: Transfer moves the impact to a third party; Mitigation reduces the risk through controls.**
- Your Answer: Transfer moves the impact to a third party; Mitigation reduces the risk through controls.

Rationale: Mitigation attempts to fix the problem; transfer passes the financial risk (e.g., insurance).

Question 9

Which of the following best describes the 'I' in the STRIDE threat modeling framework?

- **Correct Answer: Information Disclosure**
- Your Answer: Information Disclosure

Rationale: I stands for Information Disclosure, which attacks Confidentiality.

Question 10

Which access control type is intended to discourage a potential attacker from attempting an intrusion?

- **Correct Answer: Deterrent**
- Your Answer: Deterrent

Rationale: Deterrents discourage action before it happens (e.g., a "No Trespassing" sign).

Question 11

Which of the following describes the requirement that a user should only have the minimum permissions necessary to perform their job functions?

- **Correct Answer: Least Privilege**
- Your Answer: [skipped]

Rationale: This limits the scope of access to only what is absolutely required.

Question 12

An organization requires two different administrators to authorize a firewall change—one to propose the change and another to approve it. What security principle is being applied?

- **Correct Answer: Separation of Duties**
- Your Answer: Separation of Duties

Rationale: Dividing sensitive tasks prevents any one person from making unauthorized changes.

Question 13

Which component of the CIA Triad is compromised if an unauthorized user modifies the data in a database without being detected?

- **Correct Answer: Integrity**
- Your Answer: Integrity

Rationale: Integrity ensures that data has not been altered in an unauthorized way.

Question 14

What is the primary purpose of a Qualitative Risk Assessment?

- **Correct Answer: To prioritize risks based on subjective scales like High, Medium, and Low.**
- Your Answer: To prioritize risks based on subjective scales like High, Medium, and Low.

Rationale: Qualitative assessments use judgment and experience rather than complex math.

Question 15

Which of the following is an example of an Administrative Control?

- **Correct Answer: Security Awareness Training**
- Your Answer: Security Awareness Training

Rationale: Administrative controls are policies, procedures, and training managed by the organization.

Question 16

In the context of Risk Management, which term describes the risk that remains after all security controls have been implemented?

- **Correct Answer: Residual Risk**
- Your Answer: Residual Risk

Rationale: Residual risk is the leftover risk that the organization chooses to accept.

Question 17

If an asset is worth $50000 and a specific threat has an Exposure Factor (EF) of 25%, what is the Single Loss Expectancy (SLE)?

- **Correct Answer: $12500**

- Your Answer: $12500

Rationale: SLE = Asset Value x Exposure Factor.

Question 18

Which access control model relies on security labels (such as Secret or Top Secret) and clearances?

- **Correct Answer: Mandatory Access Control (MAC)**
- Your Answer: Mandatory Access Control (MAC)

Rationale: MAC uses labels for subjects and objects to enforce policy via the operating system.

Question 19

A security professional is monitoring logs and notices multiple failed login attempts from a single IP address within a very short time frame. Which phase of the monitoring process does this 'noticing' represent?

- **Correct Answer: Detection**
- Your Answer: Detection

Rationale: Detection is identifying that an event or incident has occurred.

Question 20

What is the primary benefit of 'Job Rotation' as a security control?

- **Correct Answer: It acts as a detective control to uncover fraudulent activity or errors.**
- Your Answer: It acts as a detective control to uncover fraudulent activity or errors.

Rationale: Moving people between jobs makes it harder to hide long-term fraudulent behavior.

Question 21

Which of the following describes 'Availability' in the CIA Triad?

- **Correct Answer: Ensuring authorized users have timely and reliable access to resources.**
- Your Answer: Ensuring authorized users have timely and reliable access to resources.

Rationale: Availability is focused on system uptime and accessibility.

Question 22

Which type of control is a 'Warning Sign' posted on a fence?

- **Correct Answer: Deterrent**
- Your Answer: Deterrent

Rationale: Deterrents discourage potential attackers from attempting an action.

Question 23

What does the 'S' in the STRIDE threat modeling framework stand for?

- **Correct Answer: Spoofing**
- Your Answer: Spoofing

Rationale: Spoofing is impersonating a person or system.

Question 24

In a Discretionary Access Control (DAC) environment, who has the authority to grant access to a file?

- **Correct Answer: The Data Owner**
- Your Answer: The Data Owner

Rationale: In DAC, the person who created or owns the object manages permissions.

Question 25

Which of the following is a 'Corrective' control?

- **Correct Answer: Restoring data from a backup after a ransomware attack**
- Your Answer: Restoring data from a backup after a ransomware attack

Rationale: Corrective controls repair or restore systems after a failure or breach.

Question 26

What is 'Non-repudiation'?

- **Correct Answer: The ability to ensure that a sender cannot later deny sending a message.**
- Your Answer: The ability to ensure that a sender cannot later deny sending a message.

Rationale: Non-repudiation provides legal or technical proof of action.

Question 27

Which threat modeling concept focuses on identifying the likely attackers and their motivations?

- **Correct Answer: Adversary Modeling**
- Your Answer: Adversary Modeling

Rationale: Adversary modeling profiles the potential threat actors.

Question 28

An organization decides to purchase insurance to cover potential losses from data breaches. This is an example of which risk response?

- **Correct Answer: Risk Transfer**
- Your Answer: Risk Transfer

Rationale: Passing the financial consequence of a risk to a third party is transfer.

Question 29

Which of the following is a 'Physical' control?

- **Correct Answer: Locked server cabinet**
- Your Answer: Locked server cabinet

Rationale: Physical controls are tangible barriers like locks and fences.

Question 30

What is the formula for calculating Annual Loss Expectancy (ALE)?

- **Correct Answer: ALE = SLE x ARO**
- Your Answer: ALE = SLE x ARO

Rationale: Yearly loss is the cost per event times the frequency per year.

Question 31

In Attribute-Based Access Control (ABAC), which of the following is considered an 'Environmental' attribute?

- **Correct Answer: The time of day the access is requested**
- Your Answer: The time of day the access is requested

Rationale: Environmental attributes describe the context (time, location) of the request.

Question 32

Which of the following describes 'Defense in Depth'?

- **Correct Answer: Implementing multiple layers of different security controls.**
- Your Answer: Implementing multiple layers of different security controls.

Rationale: Layered security ensures that if one control fails, others are in place.

Question 33

What is the primary goal of the 'Monitoring' phase in risk analysis?

- **Correct Answer: To identify new vulnerabilities and ensure controls are working effectively.**
- Your Answer: To identify new vulnerabilities and ensure controls are working effectively.

Rationale: Monitoring is an ongoing check of the security environment.

Question 34

Which of the following is a 'Logical' access control method?

- **Correct Answer: Access Control Lists (ACLs) on a router**
- Your Answer: Access Control Lists (ACLs) on a router

Rationale: Logical controls use technology to enforce security rules.

Question 35

Which of the following best describes the 'T' in STRIDE?

- **Correct Answer: Tampering**
- Your Answer: Tampering

Rationale: Tampering is the unauthorized modification of data (attacks Integrity).

Question 36

If an organization has a 'Risk Appetite' that is very low, which risk response are they most likely

to choose for a high-impact threat?

- **Correct Answer: Risk Avoidance**
- Your Answer: Risk Avoidance

Rationale: Avoidance eliminates the risk by not performing the activity.

Question 37

Which of the following is a 'Preventive' logical control?

- **Correct Answer: Password complexity requirements**
- Your Answer: Antivirus alerts

Rationale: Complexity requirements stop a weak password from being used. Alerts are detective.

Question 38

Which security concept ensures that a system's users are who they claim to be?

- **Correct Answer: Authentication**
- Your Answer: Authentication

Rationale: Authentication verifies identity.

Question 39

What is the term for a threat actor who uses their existing authorized access to cause harm to an organization?

- **Correct Answer: Insider Threat**
- Your Answer: Insider Threat

Rationale: Insider threats come from within the organization.

Question 40

In a Mandatory Access Control (MAC) system, what must be true for a user to access a file labeled 'Secret'?

- **Correct Answer: The user must have a 'Secret' or higher clearance and a valid 'need to know'.**
- Your Answer: The user must have a 'Secret' or higher clearance and a valid 'need to know'.

Rationale: MAC requires both appropriate labels/clearance and justification.

Question 41

What is the primary difference between a 'Threat' and a 'Vulnerability'?

- **Correct Answer: A threat is an external force that can cause harm; a vulnerability is a weakness that can be exploited.**
- Your Answer: A threat is an external force that can cause harm; a vulnerability is a weakness that can be exploited.

Rationale: Threat is the potential danger; vulnerability is the door left open.

Question 42

Which security principle is violated if a payroll clerk is able to both create a new employee record and approve their first paycheck?

- **Correct Answer: Separation of Duties**
- Your Answer: Separation of Duties

Rationale: This concentration of power allows for fraud.

Question 43

Which of the following describes a 'Detective' control?

- **Correct Answer: Reviewing system logs to find unauthorized access**
- Your Answer: Reviewing system logs to find unauthorized access

Rationale: Detective controls identify incidents after they start or finish.

Question 44

In the 'Risk Identification' process, which of the following is typically the first step?

- **Correct Answer: Inventory and value assets.**
- Your Answer: Inventory and value assets.

Rationale: You must know what you have before you can identify risks to it.

Question 45

Which of the following is an example of 'Multi-Factor Authentication' (MFA)?

- **Correct Answer: A password and a fingerprint scan**
- Your Answer: A password and a fingerprint scan

Rationale: MFA requires two or more different categories (Know, Have, Are).

Question 46

What does the 'R' in STRIDE stand for?

- **Correct Answer: Repudiation**
- Your Answer: Repudiation

Rationale: Repudiation is the ability to deny an action due to lack of evidence.

Question 47

If the Annual Rate of Occurrence (ARO) for a lightning strike is 0.1, how often is a strike expected?

- **Correct Answer: Once every 10 years**
- Your Answer: Once every 10 years

Rationale: 1 / 0.1 = 10 years.

Question 48

Which of the following is a drawback of using Mandatory Access Control (MAC)?

- **Correct Answer: It is difficult and expensive to manage.**
- Your Answer: It is difficult and expensive to manage.

Rationale: Administrative overhead for MAC is high due to labeling requirements.

Question 49

Which of the following is considered 'Accounting' in the AAA security model?

- **Correct Answer: Recording the time a user logged out and what files they accessed**
- Your Answer: Recording the time a user logged out and what files they accessed

Rationale: Accounting is about auditing and tracking actions.

Question 50

What is the primary goal of 'Change Management'?

- **Correct Answer: To ensure that changes are documented, tested, and approved to minimize risk.**
- Your Answer: To ensure that changes are documented, tested, and approved to minimize risk.

Rationale: Change management prevents unexpected failures caused by updates.

Question 51

Which of the following is an example of 'Availability' being targeted by an attacker?

- **Correct Answer: A Distributed Denial of Service (DDoS) attack taking down a website**
- Your Answer: A Distributed Denial of Service (DDoS) attack taking down a website

Rationale: DDoS aims to stop legitimate access to a service.

Question 52

What is 'Asset Valuation'?

- **Correct Answer: Determining the importance and worth of an asset to the organization.**
- Your Answer: Determining the importance and worth of an asset to the organization.

Rationale: Valuation determines how much protection an asset deserves.

Question 53

Which type of access control is 'Job Rotation' considered?

- **Correct Answer: Detective**
- Your Answer: Detective

Rationale: It uncovers fraud when a new person reviews the work of the predecessor.

Question 54

What is 'Role-Based Access Control' (RBAC)?

- **Correct Answer: Access is granted based on job functions or titles.**
- Your Answer: Access is granted based on job functions or titles.

Rationale: Roles define what a user can do.

Question 55

Which of the following is the 'I' in the STRIDE framework?

- **Correct Answer: Information Disclosure**
- Your Answer: Information Disclosure

Rationale: I attacks Confidentiality.

Question 56

An organization decides to install a sprinkler system in their data center. Which risk response does this represent?

- **Correct Answer: Risk Mitigation**
- Your Answer: Risk Mitigation

Rationale: Sprinklers reduce the impact of the fire threat.

Question 57

Which of the following is an example of 'Biometrics'?

- **Correct Answer: A retinal scan**
- Your Answer: A retinal scan

Rationale: Retinal scans are physical traits (Something you are).

Question 58

What is 'Implicit Deny'?

- **Correct Answer: A policy that blocks all traffic unless specifically allowed.**
- Your Answer: A policy that blocks all traffic unless specifically allowed.

Rationale: This is a secure-by-default configuration.

Question 59

Which phase of the monitoring cycle involves documenting and communicating the findings of a security event?

- **Correct Answer: Reporting**
- Your Answer: Reporting

Rationale: Reporting informs stakeholders about the incident.

Question 60

What does the 'E' in STRIDE stand for?

- **Correct Answer: Elevation of Privilege**
- Your Answer: Elevation of Privilege

Rationale: E is gaining rights beyond what is authorized.

Question 61

An organization uses an automated system to grant access based on a combination of user location, time of day, and the security posture of the device being used. Which access control model is being utilized?

- **Correct Answer: Attribute-Based Access Control (ABAC)**
- Your Answer: Attribute-Based Access Control (ABAC)

Rationale: ABAC uses dynamic attributes from subjects, objects, and environment.

Question 62

Which of the following represents a 'Quantitative' risk assessment metric?

- **Correct Answer: The Single Loss Expectancy (SLE) is calculated at $4500.**
- Your Answer: The Single Loss Expectancy (SLE) is calculated at $4500.

Rationale: Quantitative uses hard numbers and currency.

Question 63

In the event of a system failure, a security professional ensures that the system defaults to a state that prevents unauthorized access, even if it impacts availability. What is this concept called?

- **Correct Answer: Fail-safe**
- Your Answer: Fail-over

Rationale: Fail-safe defaults to a secure state. Fail-over is a high-availability switch.

Question 64

Which security concept is primarily supported by the use of digital signatures?

- **Correct Answer: Non-repudiation**
- Your Answer: Non-repudiation

Rationale: Signatures prove origin and integrity, preventing denial of action.

Question 65

Which of the following is a primary objective of a 'Vulnerability Management' program?

- **Correct Answer: To regularly identify, classify, and remediate security weaknesses.**
- Your Answer: To regularly identify, classify, and remediate security weaknesses.

Rationale: Continuous scanning and patching is the core of this program.

Question 66

Which of the following is an example of a 'Physical' detective control?

- **Correct Answer: CCTV cameras recording entry points**
- Your Answer: CCTV cameras recording entry points

Rationale: CCTV provides a record of what happened physically.

Question 67

What is the primary risk associated with 'Risk Acceptance'?

- **Correct Answer: The organization must bear the full impact if the threat occurs.**

- Your Answer: The organization must bear the full impact if the threat occurs.

Rationale: Acceptance means no controls are in place to reduce damage.

Question 68

Which of the following best describes the 'Need to Know' principle?

- **Correct Answer: A user is granted access only to the specific data required to perform a specific task.**
- Your Answer: A user is granted access only to the specific data required to perform a specific task.

Rationale: This is the most granular application of least privilege for data access.

Question 69

What is the result of multiplying the Asset Value by the Exposure Factor (EF)?

- **Correct Answer: Single Loss Expectancy (SLE)**
- Your Answer: Single Loss Expectancy (SLE)

Rationale: SLE = AV x EF.

Question 70

Which component of the STRIDE model is mitigated by using strong encryption for data in transit?

- **Correct Answer: Information Disclosure**
- Your Answer: Tampering

Rationale: Encryption hides data (attacks Information Disclosure). Tampering is attacks integrity.

Question 71

An administrator uses a 'Honeycomb' or 'Honeypot' to observe the techniques used by attackers. This is an example of which security activity?

- **Correct Answer: Risk Identification**
- Your Answer: Risk Identification

Rationale: Honeypots help identify the nature of incoming threats.

Question 72

Which of the following is a primary characteristic of Discretionary Access Control (DAC)?

- **Correct Answer: The resource owner has the ability to transfer permissions to others.**
- Your Answer: The resource owner has the ability to transfer permissions to others.

Rationale: Discretion lies with the individual data owner.

Question 73

Which phase of the Risk Management Life Cycle involves determining the effectiveness of existing controls?

- **Correct Answer: Risk Assessment**
- Your Answer: Risk Assessment

Rationale: Assessment evaluates existing risks and the controls meant to stop them.

Question 74

What is the primary difference between 'Least Privilege' and 'Separation of Duties'?

- **Correct Answer: Least privilege limits power; separation of duties divides a process.**
- Your Answer: Least privilege limits power; separation of duties divides a process.

Rationale: LP is about amount of access; SoD is about splitting the task.

Question 75

Which 'A' in the AAA framework is responsible for determining what a verified user is allowed to do?

- **Correct Answer: Authorization**
- Your Answer: Authorization

Rationale: Authorization maps rights to the user's identity.

Question 76

An organization experiences a server crash once every four years. What is the Annual Rate of Occurrence (ARO)?

- **Correct Answer: 0.25**
- Your Answer: 0.4

Rationale: 1 crash / 4 years = 0.25.

Question 77

Which of the following is a 'Corrective' technical control?

- **Correct Answer: A system automatically rebooting a service that has stopped responding**
- Your Answer: A system automatically rebooting a service that has stopped responding

Rationale: It automatically fixes the service state after failure.

Question 78

What does 'Social Engineering' primarily target?

- **Correct Answer: Human psychology and trust**
- Your Answer: Human psychology and trust

Rationale: Social engineers manipulate people rather than technology.

Question 79

Which of the following describes the 'Integrity' component of the CIA Triad?

- **Correct Answer: Data is accurate and has not been altered by unauthorized parties.**
- Your Answer: Data is accurate and has not been altered by unauthorized parties.

Rationale: Integrity ensures trustworthiness of data.

Question 80

In threat modeling, what is an 'Attack Surface'?

- **Correct Answer: The sum of all points where an unauthorized user can try to enter or extract data.**
- Your Answer: The sum of all points where an unauthorized user can try to enter or extract data.

Rationale: Attack surface is the total exposure of the system.

Question 81

Which of the following is an 'Administrative' detective control?

- **Correct Answer: Mandatory vacations**
- Your Answer: Mandatory vacations

Rationale: Policy-based discovery of fraud during employee absence.

Question 82

What is 'Role-Based Access Control' (RBAC) also known as?

- **Correct Answer: Non-Discretionary Access Control**
- Your Answer: User-Based Access Control

Rationale: Access isn't up to the user or owner (it's non-discretionary).

Question 83

Which of the following is a 'Deterrent' physical control?

- **Correct Answer: A 'Restricted Area: Authorized Personnel Only' sign**
- Your Answer: A deadbolt lock

Rationale: Signs discourage; locks prevent.

Question 84

Which STRIDE category involves an attacker sending a large amount of traffic to a server to crash it?

- **Correct Answer: Denial of Service**
- Your Answer: Denial of Service

Rationale: DoS targets Availability.

Question 85

What is 'Residual Risk' in a mathematical sense?

- **Correct Answer: Total Risk - Mitigated Risk**
- Your Answer: Total Risk - Mitigated Risk

Rationale: It's the risk left over after controls are applied.

Question 86

Which access control model uses 'Clarity and Clearances' to protect data?

- **Correct Answer: Mandatory Access Control (MAC)**
- Your Answer: Mandatory Access Control (MAC)

Rationale: MAC maps clearances to classification labels.

Question 87

Which of the following is an 'Environmental' factor in a risk assessment?

- **Correct Answer: The likelihood of a flood in the data center's region**
- Your Answer: The likelihood of a flood in the data center's region

Rationale: Environmental factors are outside organizational control (nature).

Question 88

What is the primary purpose of 'Audit Trails'?

- **Correct Answer: To provide a chronological record of system activities and user actions.**
- Your Answer: To provide a chronological record of system activities and user actions.

Rationale: Audit trails provide accountability via logging.

Question 89

Which component of the CIA Triad is compromised if a web server is taken offline by a power outage?

- **Correct Answer: Availability**
- Your Answer: Availability

Rationale: Outages stop users from reaching the system.

Question 90

What is the primary goal of 'Security Governance'?

- **Correct Answer: To ensure security strategies align with business objectives and laws.**
- Your Answer: To ensure security strategies align with business objectives and laws.

Rationale: Governance is high-level strategic oversight.

Question 91

If an organization has a 'Risk Tolerance' for $5000 and a specific risk is calculated to have an ALE of $2000, what is the most likely response?

- **Correct Answer: Risk Acceptance**
- Your Answer: Risk Acceptance

Rationale: Risks within tolerance are typically accepted.

Question 92

Which of the following is an example of 'Two-Factor Authentication' (2FA)?

- **Correct Answer: A hardware token and a fingerprint scan**
- Your Answer: A hardware token and a fingerprint scan

Rationale: 2FA requires two different categories.

Question 93

What is the primary function of a 'Data Custodian'?

- **Correct Answer: To maintain the technical environment and implement the owner's security requirements.**
- Your Answer: To decide who should have access to the data.

Rationale: Owners decide access; custodians maintain the system.

Question 94

In the STRIDE framework, which category involves an attacker pretending to be a legitimate email server?

- **Correct Answer: Spoofing**
- Your Answer: Spoofing

Rationale: Spoofing is identity impersonation.

Question 95

Which of the following describes a 'Preventive' administrative control?

- **Correct Answer: Hiring only those who pass a background check**
- Your Answer: Hiring only those who pass a background check

Rationale: HR policies prevent untrustworthy people from entering.

Question 96

What is the primary risk of using 'Discretionary Access Control' (DAC)?

- **Correct Answer: It can result in inconsistent security because individual owners make decisions.**
- Your Answer: It is too rigid and difficult to change.

Rationale: DAC is flexible but lacks centralized oversight.

Question 97

Which 'phase' of the risk management process involves identifying the 'Threat Agents'?

- **Correct Answer: Risk Identification**
- Your Answer: Risk Identification

Rationale: Identification names what or who can hurt the organization.

Question 98

What is the goal of the 'Least Privilege' principle during the onboarding of a new employee?

- **Correct Answer: To provide only the permissions needed for their specific job role and nothing more.**
- Your Answer: To provide only the permissions needed for their specific job role and nothing more.

Rationale: LP ensures the smallest attack surface for the user.

Question 99

Which component of the STRIDE model is addressed by maintaining robust and unalterable system logs?

- **Correct Answer: Repudiation**
- Your Answer: Repudiation

Rationale: Logs provide evidence, preventing denial of action.

Question 100

What is the primary difference between a 'Hot Site' and a 'Cold Site' for disaster recovery?

- **Correct Answer: A hot site is fully equipped and has live data; a cold site is just space with basic utilities.**
- Your Answer: A hot site is fully equipped and has live data; a cold site is just space with basic utilities.

Rationale: Hot site is ready now; cold site requires time to setup.

Question 101

Which access control model is most associated with 'Labels' and 'Classifications'?

- **Correct Answer: Mandatory Access Control (MAC)**
- Your Answer: Mandatory Access Control (MAC)

Rationale: Labels define sensitivity in MAC.

Question 102

An organization experiences 10 hard drive failures a year. Each failure costs $300 to replace and restore. What is the ALE?

- **Correct Answer: $3000**
- Your Answer: $3000

Rationale: 10 x 300 = 3000.

Question 103

What is the primary benefit of 'Security Awareness Training'?

- **Correct Answer: It turns employees into a 'human firewall' to detect and report threats.**
- Your Answer: It turns employees into a 'human firewall' to detect and report threats.

Rationale: Training makes users part of the defense.

Question 104

Which of the following is a 'Technical' preventive control?

- **Correct Answer: A firewall blocking all traffic from a known malicious IP**
- Your Answer: A firewall blocking all traffic from a known malicious IP

Rationale: Firewalls stop (prevent) traffic using technology.

Question 105

What does 'Threat Modeling' help an organization identify?

- **Correct Answer: Potential threats and the likely paths an attacker would take.**
- Your Answer: Potential threats and the likely paths an attacker would take.

Rationale: Modeling maps the threat landscape.

Question 106

Which of the following is an example of 'Risk Avoidance'?

- **Correct Answer: Deciding not to launch a new app because the security risks are too high.**
- Your Answer: Deciding not to launch a new app because the security risks are too high.

Rationale: Stopping the activity stops the risk.

Question 107

What is 'Privilege Creep'?

- **Correct Answer: The gradual accumulation of unnecessary access rights by an employee over time.**
- Your Answer: The gradual accumulation of unnecessary access rights by an employee over time.

Rationale: Rights aren't removed when people change roles.

Question 108

Which of the following describes 'Logical' access control?

- **Correct Answer: Software-based mechanisms like passwords and encryption.**
- Your Answer: Software-based mechanisms like passwords and encryption.

Rationale: Logical is synonymous with technical software/data controls.

Question 109

What is the primary difference between 'Authentication' and 'Authorization'?

- **Correct Answer: Authentication proves identity; authorization defines rights.**
- Your Answer: Authentication proves identity; authorization defines rights.

Rationale: Identity first, permissions second.

Question 110

Which 'S' in the STRIDE model relates most to the compromise of 'Confidentiality'?

- **Correct Answer: The STRIDE model doesn't have an 'S' for confidentiality; that is the 'I'.**
- Your Answer: Spoofing

Rationale: I is Information Disclosure (Confidentiality).

Question 111

An organization sets a goal that after a system failure, services must be restored within 4 hours. What is this metric called?

- **Correct Answer: Recovery Time Objective (RTO)**
- Your Answer: Recovery Time Objective (RTO)

Rationale: RTO is the maximum allowed downtime.

Question 112

Which phase of the Data Life Cycle is most concerned with the secure use of cryptographic keys to protect data while it is being viewed by an application?

- **Correct Answer: Usage**
- Your Answer: Usage

Rationale: Usage is when data is in memory/processed.

Question 113

A security professional is implementing a 'Scoping' exercise for a new compliance project. What does this activity involve?

- **Correct Answer: Determining which specific systems and assets are subject to the security requirements.**
- Your Answer: Determining which specific systems and assets are subject to the security requirements.

Rationale: Scoping defines the audit or compliance boundary.

Question 114

Which of the following describes the 'Due Care' principle?

- **Correct Answer: The act of implementing specific security controls that a 'reasonable person' would perform.**
- Your Answer: The act of implementing specific security controls that a 'reasonable person' would perform.

Rationale: Due Care is the performance of security duties.

Question 115

In the context of the AAA framework, which process typically follows Authorization?

- **Correct Answer: Accounting**
- Your Answer: Accounting

Rationale: Audit what the authorized user does.

Question 116

Which type of control is a 'Termination Policy' that requires an employee to return all company assets on their last day?

- **Correct Answer: Administrative Preventive**
- Your Answer: Administrative Preventive

Rationale: Policies are administrative; this prevents theft.

Question 117

An organization wants to ensure that no single person has enough authority to execute a high-value financial transaction from start to finish. Which principle should they apply?

- **Correct Answer: Separation of Duties**
- Your Answer: Separation of Duties

Rationale: Process division prevents individual fraud.

Question 118

What is the primary difference between a 'Vulnerability Scan' and a 'Penetration Test'?

- **Correct Answer: A scan identifies potential weaknesses; a penetration test attempts to exploit them.**
- Your Answer: A scan identifies potential weaknesses; a penetration test attempts to exploit them.

Rationale: Testing goes further to prove the risk.

Question 119

In Risk Analysis, if the Single Loss Expectancy (SLE) is 10000 and the Annual Loss Expectancy (ALE) is 5000, what is the Annual Rate of Occurrence (ARO)?

- **Correct Answer: 0.5**
- Your Answer: 2

Rationale: ARO = ALE / SLE. 5000 / 10000 = 0.5.

Question 120

Which of the following is considered a 'Compensating' control?

- **Correct Answer: Using a log review process because a system cannot support strong encryption.**
- Your Answer: Using a log review process because a system cannot support strong encryption.

Rationale: Compensating controls take over when primary controls fail or are impossible.

Question 121

Which element of the STRIDE framework is directly countered by the use of hashing and digital signatures to ensure data hasn't been changed?

- **Correct Answer: Tampering**

- Your Answer: Tampering

Rationale: Tampering attacks integrity; hashes protect it.

Question 122

What is the primary purpose of 'Tailgating' as a social engineering technique?

- **Correct Answer: To gain physical access to a restricted area by following an authorized person.**
- Your Answer: To gain physical access to a restricted area by following an authorized person.

Rationale: Tailgating relies on human social norms to bypass locks.

Question 123

Which document defines the high-level security goals and the overall commitment of management to security?

- **Correct Answer: Security Policy**
- Your Answer: Security Policy

Rationale: Policies are management-level directives.

Question 124

A user is required to use their smart card and a 6-digit PIN to log in. What type of authentication factors are being used?

- **Correct Answer: Something you have and something you know.**
- Your Answer: Something you have and something you know.

Rationale: Card = Have; PIN = Know.

Question 125

Which risk response is being used when an organization decides to outsource its email hosting to a provider that guarantees 99.9% uptime?

- **Correct Answer: Risk Transfer**
- Your Answer: Risk Transfer

Rationale: Outsourcing passes operational risk to the vendor.